

Aluno: Adriana Dantas Marotti

Email Hacking, Ataques e Defesa Atual

A apresentação aborda o estado atual da segurança de e-mail, um protocolo que, apesar de antigo, continua sendo um pilar da comunicação na internet. Hannu Aronsson, oferece uma análise técnica e prática sobre como o cenário de ameaças evoluiu e como as defesas devem se adaptar.

O contexto central da palestra é a mudança de paradigma nas ameaças digitais pelo e-mail. Há cinco ou dez anos, o principal problema enfrentado por administradores de sistemas e usuários finais era o volume massivo de spam genérico. Hoje, embora o volume de spam tenha se estabilizado e os filtros tenham melhorado, o centro de ataque tornou-se muito mais perigoso: o phishing, e especificamente o spear phishing (ataques direcionados)

Aronsson destaca que o e-mail permanece como o principal ponto de entrada para malware e ransomware nas organizações. A sofisticação aumentou drasticamente com o uso de Inteligência Artificial, permitindo que atacantes personalizem mensagens para cada destinatário, tornando a identificação de fraudes muito mais difícil para o usuário comum. Além disso, o cenário é complicado pela fragmentação dos clientes de e-mail (Outlook, Gmail, Apple Mail, etc.), onde cada aplicativo exibe as informações de cabeçalho e remetente de maneira diferente, dificultando uma padronização na verificação visual de segurança.

2. Objetivos da Apresentação

O objetivo principal da apresentação é atualizar profissionais de segurança, administradores de sistemas e usuários avançados sobre a situação atual dos ataques de e-mail e as metodologias de defesa mais eficazes. Aronsson busca esclarecer conceitos técnicos que frequentemente são mal compreendidos, e fornecer um roteiro claro de "melhores práticas".

A apresentação visa:

1. Educar sobre a Anatomia do E-mail
2. Analisar Protocolos de Autenticação
3. Expor Novas Táticas de Ataque
4. Incentivar o uso de padrões abertos e configurações que não quebrem o fluxo de e-mail, especialmente em cenários complexos de encaminhamento (forwarding).

3. Principais Tópicos Abordados

A Evolução das Ameaças: Do Spam ao BEC

O vídeo enfatiza que o Business Email Compromise (BEC) é uma das ameaças mais financeiramente prejudiciais atualmente. Um exemplo é a falsificação de um e-mail do CEO instruindo o departamento financeiro a realizar uma transferência bancária urgente. Como o e-mail parece vir de uma fonte interna e confiável, as defesas tradicionais e a atenção humana frequentemente falham.

Além disso, há uma tendência crescente de malware focado no roubo de credenciais e "cookies de sessão", especialmente para logins do Microsoft 365. Isso permite que atacantes não apenas enviem e-mails falsos, mas acessem a caixa de entrada real do usuário, ignorando completamente as barreiras de segurança de entrada.

Envelope x Cabeçalhos

Distinção entre o "Envelope Address" (usado pelo protocolo SMTP para entrega) e o endereço "From" (visível no corpo do email)

- Ele mostra como enviou um e-mail fingindo ser de uma "memecoin", que foi aceito pelo servidor e entregue, ilustrando que o protocolo base do e-mail não valida nativamente se o remetente é quem diz ser
- A maioria dos clientes de e-mail modernos esconde essa complexidade, mostrando apenas o nome amigável do remetente, o que facilita o engano

Pilares de autenticação de email

SPF (Sender Policy Framework)

- Conceito: Uma lista DNS de IPs autorizados a enviar emails em nome de um domínio.
- O SPF falha em cenários de encaminhamento (forwarding). Se um email é redirecionado automaticamente de uma conta universitária para um Gmail pessoal, o IP do servidor da universidade não estará no SPF do remetente original, causando falha.
- Administradores configuram SPF com -all (hard fail) esperando bloquear spam, mas acabam bloqueando emails legítimos encaminhados.
- Incluir o SPF do Outlook/Microsoft 365 autoriza milhares de endereços IP a enviar email em seu nome. Atacantes podem usar uma conta legítima na mesma nuvem para enviar emails que passam na validação SPF do seu domínio, pois ambos saem da mesma infraestrutura.

DKIM (DomainKeys Identified Mail)

- Assina criptograficamente o conteúdo do email e os cabeçalhos. Diferente do SPF, a assinatura DKIM sobrevive ao encaminhamento de e-mails, desde que o conteúdo não seja alterado.
- Atacantes podem pegar um e-mail válido assinado, tipo um e-commerce, e reenviá-lo.
- O padrão DKIM permite múltiplas assinaturas, um atacante pode adicionar um novo cabeçalho "Subject" malicioso se a assinatura original não "trancar" esse campo. Aronsson recomenda a técnica de "Oversigning" (assinar campos-chaves repetidamente) para impedir a inserção de novos cabeçalhos falsos.

DMARC (Domain-based Message Authentication, Reporting, and Conformance)

- O DMARC une o SPF e o DKIM. Ele permite que o dono do domínio publique uma política sobre o que fazer se a validação falhar (Nada, Quarentena ou Rejeição).
- Visibilidade: Uma característica pouco utilizada, mas vital, é o relatório. O DMARC permite receber relatórios estatísticos sobre quem está enviando emails em seu nome, permitindo identificar configurações erradas.

- Não pule direto para a política de "reject". Comece monitorando, pois configurações estritas podem causar perda de e-mails legítimos devido à "sujeira" e inconsistências dos sistemas de e-mail globais

ARC (Authenticated Received Chain)

Para resolver o problema histórico de quebra de autenticação em encaminhamentos (onde o SPF falha e o DKIM pode quebrar se o intermediário alterar o assunto ou corpo), Aronsson introduz o ARC. O ARC permite que intermediários (como listas de discussão ou serviços de hospedagem) assinem a "cadeia de custódia", afirmando que validaram a autenticação original antes de encaminhar a mensagem. Embora ainda dependa de confiança mútua, é uma peça fundamental para a infraestrutura moderna.

Melhores práticas para empresas e provedores

Para empresas:

- Não confie apenas no SPF, pois ele é ultrapassado como mecanismo único. Use como backup.
- Implemente DKIM e DMARC, assim todo email que sai é assinado
- Separação de tráfego: usar blocos de IP diferentes para emails corporativos importantes e emails de marketing para proteger a integridade do domínio principal
- IPs estáticos: Evite usar IPs dinâmicos de nuvem para envio de e-mail, pois eles podem ter sido usados por spammers minutos antes

Para receptores (Departamentos de TI):

- Tolerância: Não rejeitar emails apenas porque o SPF falhou. Se o DKIM passar ou se outros filtros de conteúdo não detectarem spam, deixe passar.
- Em vez de bloquear silenciosamente, coloque mensagens suspeitas em quarentena (Junk folder). Isso ajuda o usuário e permite a recuperação de falsos positivos

Por fim, é mencionado na paleta inovações como:

- EAI (Email Address Internationalization): suporte para caracteres Unicode e emojis em endereços de e-mail
- BIMl (Brand Indicators for Message Identification): Um padrão que permite as empresas exibir seus logotipos verificados nos clientes de e-mail, funcionando como um incentivo para a adoção de DMARC estrito

Apesar de suas falhas e idade, o e-mail continua sendo uma ferramenta insubstituível de identidade digital e comunicação aberta, exigindo manutenção constante e colaboração comunitária para permanecer seguro.

Implementação (Valor 5) Crie um bot que joga o jogo Cookie Clicker. Ele deve no mínimo conseguir clicar no biscoito grande e nos biscoitos dourados.

Foi feita a implementação diretamente pelo console do DevTools via javascript:

```
var cookieBot = setInterval(function() {  
  
    var bigCookie = document.getElementById('bigCookie');  
    if (bigCookie) {  
        bigCookie.click();  
    }  
  
    var goldenCookies =  
document.getElementsByClassName('shimmer');  
  
    for (var i = 0; i < goldenCookies.length; i++) {  
        if (goldenCookies[i]) {  
            goldenCookies[i].click();  
            console.log("biscoito dourado capturado");  
        }  
    }  
  
}, 10); //roda a cada 10 milissegundos
```

para parar de rodar, so enviar clearInterval(cookieBot);